EXECUTIVE SUMMARY

Closing the agentic gap in 90 days

Attacker with AI agents	minutes	access → lateral movement: avg 29 min, fastest 27 s
Our response today	alert → analyst → approval → action: tens of minutes to hours	

Faster
AI agents run recon, credential theft and lateral movement in parallel

Quieter
Stolen identities and our own admin tools instead of malware

Cheaper
Attacks that took a skilled team now run as automation, at scale

DECISION Approve automated containment for near-certain attacks. Sign policy by day 30.

Risk reduction

AGENTIC ATTACK STEP	TODAY	DAY 30	DAY 60	DAY 90	WHAT MOVES IT
Breaks in through exposed systems	🔴	🟡	🟡	🟡	Admin pages off internet, 72 h patching
Logs in with stolen credentials	🔴	🔴	🟡	🟡	Phishing-resistant admin MFA, auto sign-out + reset
Harvests credentials on a machine	🔴	🟡	🟡	🟢	Decoy credentials, auto-isolate on theft
Blinds our security tools	🔴	🟡	🟡	🟢	Log-silence alerts, EDR tamper detection
Agentic lateral movement	🔴	🟡	🟢	🟢	Decoy accounts, machine-speed recon detection
Agentic malware / ransomware	🔴	🟡	🟡	🟢	EDR block mode, auto-isolate on ransomware prep
Takes over cloud accounts	🔴	🔴	🔴	🟡	Auto-restore logging, cut off stolen keys

🔴 Not stopped in time 🟡 Detected, human-speed response 🟢 Contained automatically or prevented

For the board

1. AI lets attackers move in minutes; our response takes hours.
2. This plan cuts the chance an agentic intrusion becomes a company-wide incident by **about half**, measured by live simulation at day 90.
3. Automation only acts where it can't hurt the business, and every action can be undone.

Requirements

- Every automated action is reversible in one click
- No automated action can take down the business
- A maintained list of what can and can't be auto-contained
- Every action logged and explainable to the person affected

Asks

Sign containment policy	Day 30
Mandate phishing-resistant MFA for admins	Day 1
Edge admin pages off the internet	Day 30
15 min per app owner for server sign-off	Day 60

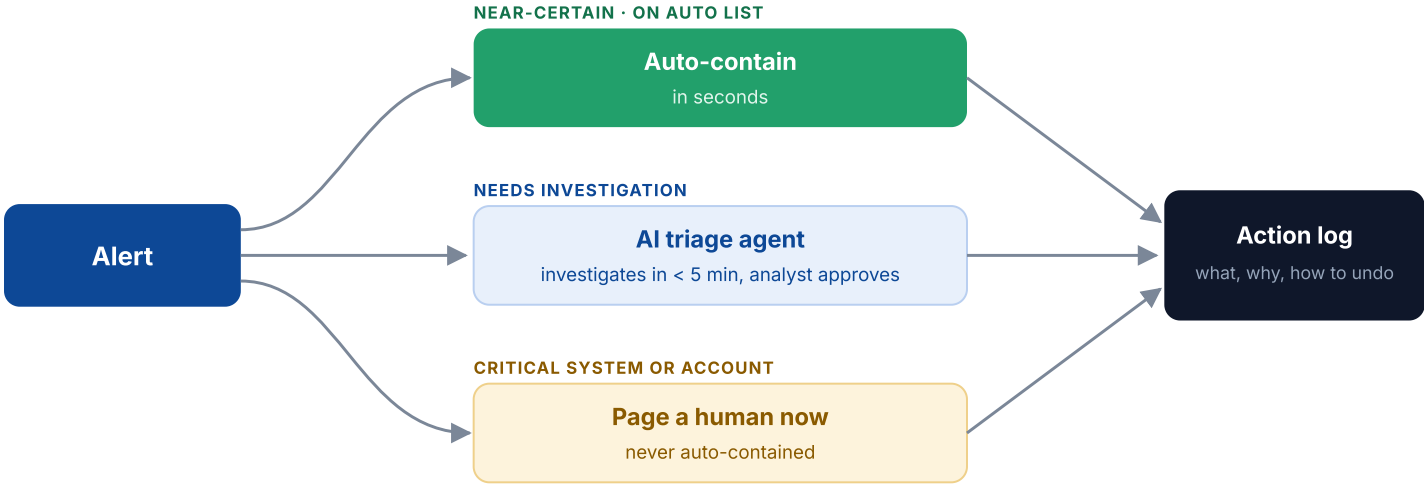
Day 90 targets

Detect → contain (simulation)	< 5 min
Attack types auto-contained	9
EDR in block mode	> 95%
Admins on phishing-resistant MFA	100%

ENGINEERING

How it works

Every alert takes one of three paths



The containment list

Auto

Contained in seconds when a near-certain detection fires. Starts with every workstation and standard user.

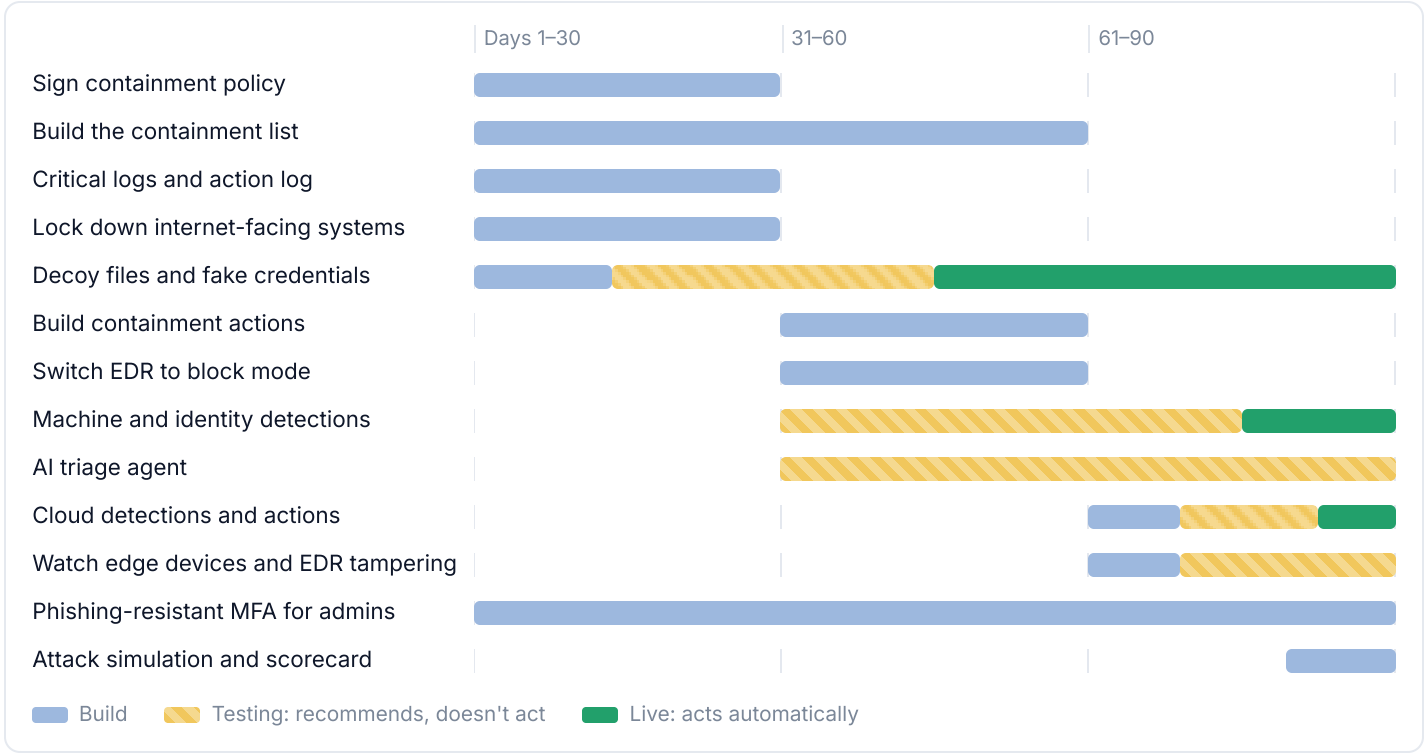
Limited

Stop the process, block the site, sign the user out, then page. Default for servers until the owner signs off.

Human only

Domain controllers, hypervisors, identity, backup, security tools, break-glass and root accounts.

90-day timeline



ENGINEERING

To-do by phase

Days 1–30 · authorize and see

- [ ] Draft the containment policy in week 1; get it signed by day 30
- [ ] Put every workstation and standard user on the auto list; servers start as limited
- [ ] List human-only accounts: break-glass, service, sync, cloud admin, automation
- [ ] Stand up the action log; help desk can look up any user or machine
- [ ] Get critical logs flowing with under 5 min delay and an alert if any go silent
- [ ] Inventory internet-facing systems; patch actively exploited bugs within 72 h
- [ ] Take edge admin pages off the internet; put VPN behind SSO + MFA
- [ ] Deploy decoy files, fake credentials and decoy AD accounts in testing mode
- [ ] Start phishing-resistant MFA rollout for admins
- [ ] Run the blind spot agent daily (read-only)

Exit: policy signed · workstations on the auto list · action log live · first blind spot report

Days 31–60 · build actions, learn the noise

- [ ] Add safety to every action: list check, one-click and bulk undo, rate limits that page on-call
- [ ] Build and test: isolate machine, kill process, block site or IP
- [ ] Build and test: sign out everywhere, disable account, reset password and MFA
- [ ] EDR on 95%+ of machines in block mode with anti-tamper; review exclusions
- [ ] Switch decoys to live, with the mass-hit breaker on
- [ ] Testing mode: credential theft, MFA fatigue, machine-speed recon, ransomware prep
- [ ] AI triage agent on high alerts, risky sign-ins, new MFA methods, server shells
- [ ] Tune noise with narrow, expiring exceptions
- [ ] Get server owners' sign-off; no answer stays limited

Exit: every action run and undone on a test target · decoys live · every high alert investigated

Days 61–90 · cloud, edge, go live

- [ ] Cloud: revoke stolen credentials safely; auto-restore disabled logging
- [ ] Cloud detections: logging turned off, keys used outside the cloud, new admin or root use
- [ ] Send edge admin logins and config changes to triage
- [ ] EDR tampering: act only with a second signal; test the outage circuit breaker
- [ ] Inventory AI agents that can send, change or run code
- [ ] Review each tested rule; switch the ones that pass to live
- [ ] Phishing-resistant MFA on 100% of admins
- [ ] Run the attack simulation; record detect-to-contain time

Exit: 9 detections live · detect-to-contain measured · scorecard to CISO

ENGINEERING

Detections, actions, thresholds

Detection → response

DETECTION	RESPONSE	DAY 90
Decoy / fake credential touched	isolate · sign out	AUTO
Decoy AD account used	isolate source	AUTO
Credential theft	isolate · sign out · reset · block C2	AUTO
MFA fatigue → approve	sign out · remove new MFA · reset	AUTO
Recon burst (≥ N cmds / 60 s)	isolate workstation · sign out	AUTO
Ransomware prep	isolate · disable · block	AUTO
Cloud logging disabled	restore logging · revoke cloud creds	AUTO
Cloud keys used outside provider	revoke cloud sessions · page	AUTO
EDR tamper + 2nd signal	sign out · isolate · page	AUTO
EDR tamper alone	triage decides	RECOMMEND
EDR high / critical	triage	RECOMMEND
Risky sign-in	triage · sign out / reset	RECOMMEND
New MFA method / help-desk reset	triage · remove method	RECOMMEND
Server spawns shell	triage · isolate / kill	RECOMMEND
New admin, root / break-glass use	triage · revert	RECOMMEND
Edge admin / config change	triage · disable admin · block IP	RECOMMEND
Prompt injection in evidence	human decides	HUMAN

Cloud: action by identity type

People

revoke sessions · deactivate key · deny-all

Workloads

revoke sessions

Workload gets fresh credentials; the attacker's copy dies.

Root · break-glass · org admin

page only

Disabled logging is always restored.

Thresholds to configure

Testing period: ≥ 2 weeks per rule

Go live when: ≤ 1 false positive / month, fired once

AI agent acts when: 30 cases · ≥ 95% agree · 0 harmful

Rate limits: per rule + per action → stop + page

EDR outage breaker: > 2% sensors silent / hour → no auto

Decoy breaker: > 3 machines / 15 min → one incident

Not on the list: treat as limited

Exceptions: narrowest match · owner · ≤ 12 months

Targets come from: alert fields only, never free text

Auto actions: only on the auto list